

Security+ 1.4 · Hashing & Digital Signatures

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 1.4 — Hashing & Digital Signatures (10:24)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Hash = impressão digital mão única: SHA-256/SHA-3 padrão; MD5/SHA-1 quebrados. Assinatura digital = cifrar o hash com a chave PRIVADA — qualquer um valida com a pública. Garante integridade + autenticidade + non-repudiation (3 objetivos).

Highlights que a prova cobra

- SHA-256 padrão; MD5/SHA-1 quebrados (collision)
- Assinatura = hash cifrado com chave PRIVADA de quem assina
- Avalanche effect: 1 bit mudou = hash inteiro mudou

Dicas de prova & Cenários Típicos

- 'provides integrity but not confidentiality' = hash
- 'cannot deny that they signed' = digital signature (non-repudiation)

Cenário clássico de exame: Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar que não foi alterado' = integridade por hash.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 1.4 — Hashing & Digital Signatures)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Pra garantir que um arquivo NÃO foi alterado (integridade), tu usa:

- A) Compressão ZIP
- B) Função hash (ex: SHA-256)
- C) Criptografia AES
- D) Assinatura Base64

2. Uma característica de HASH (diferente de criptografia) é que ele:

- A) Pode ser revertido com a chave
- B) É de mão única (não reversível)
- C) Sempre encurta o texto pela metade
- D) Precisa de par de chaves

3. A forma correta de ARMAZENAR senhas de usuários:

- A)** Hash com salt (ex: bcrypt)
- B)** Criptografia AES reversível
- C)** Texto claro protegido por firewall
- D)** Base64

4. Qual função criptográfica NÃO é reversível?

- A)** Criptografia AES
- B)** Criptografia RSA
- C)** Hash SHA-256
- D)** Codificação Base64

5. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'SHA-256 padrão; MD5/SHA-1 quebrados (collision)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: SHA-256 padrão; MD5/SHA-1 quebrados (collision)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Assinatura = hash cifrado com chave PRIVADA de quem assina'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Assinatura = hash cifrado com chave PRIVADA de quem assina...

7. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Avalanche effect: 1 bit mudou = hash inteiro mudou'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Avalanche effect: 1 bit mudou = hash inteiro mudou...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: '"provides integrity but not confidentiality' = hash'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'provides integrity but not confidentiality' = hash...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: '"cannot deny that they signed' = digital signature (non-repudiation)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'cannot deny that they signed' = digital signature (non-repudiation)...

10. Cenário corporativo (Hashing & Digital Signatures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar que não foi alterado' = integridade por hash.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar q...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Função hash (ex: SHA-256).

✓ **Por que está certa:** Para garantir a integridade de um arquivo, ou seja, assegurar que ele não foi alterado, utiliza-se uma função hash criptográfica, como SHA-256. Uma função hash gera um resumo de tamanho fixo (digest) a partir dos dados de entrada. Qualquer alteração mínima no arquivo produz um hash completamente diferente (efeito avalanche). Assim, ao comparar o hash calculado antes e depois da transmissão ou armazenamento, é possível detectar modificações. O SHA-256 é um algoritmo amplamente recomendado pelo NIST e pelo CompTIA Security+ para verificação de integridade, pois é resistente a colisões e pré-imagem. A integridade é um dos pilares da tríade CIA e o hash é o mecanismo padrão para verificá-la.

✗ Por que as outras estão erradas:

- *Compressão ZIP:* A compressão ZIP é uma técnica para reduzir o tamanho de arquivos, agrupando-os em um contêiner. Ela não fornece garantia de integridade, pois não gera um resumo criptográfico que permita detectar alterações. Um arquivo ZIP pode ser modificado sem que haja qualquer mecanismo intrínseco de verificação. Embora o formato ZIP suporte CRC-32 para detectar erros acidentais, esse é um checksum não criptográfico, vulnerável a alterações maliciosas. Portanto, ZIP não atende ao requisito de integridade forte exigido em segurança da informação.
- *Criptografia AES:* A criptografia AES (Advanced Encryption Standard) é um algoritmo de cifra simétrica usado para confidencialidade, não para integridade. Ela transforma texto claro em texto cifrado, mas não fornece um meio direto de verificar se o dado foi alterado. Na verdade, se um atacante modificar o texto cifrado, a descifragem pode produzir texto claro incorreto ou falhar, mas sem um mecanismo de autenticação (como HMAC ou modo GCM), não há garantia de detecção. AES por si só não é uma função hash e não produz um resumo de integridade. Para integridade, é necessário um hash ou um código de autenticação de mensagem (MAC).
- *Assinatura Base64:* Base64 é um esquema de codificação que representa dados binários em texto ASCII, usado para transporte em protocolos como e-mail (MIME). Não é uma assinatura digital nem um mecanismo de integridade. Base64 não fornece qualquer garantia de que o conteúdo não foi alterado; é meramente uma transformação reversível. O termo 'assinatura Base64' é um equívoco, pois assinaturas digitais envolvem criptografia assimétrica e funções hash. Portanto, Base64 não serve para verificar integridade.

2) B — É de mão única (não reversível).

✓ **Por que está certa:** Uma característica fundamental das funções hash criptográficas é serem de mão única (one-way), ou seja, não reversíveis. Isso significa que, a partir do hash, não é possível recuperar a mensagem original. Essa propriedade é conhecida como resistência à pré-imagem. Diferentemente da criptografia, que é reversível com a chave correta, o hash é projetado para ser irreversível. O CompTIA Security+ destaca que funções hash como SHA-256 são usadas para integridade e armazenamento de senhas (com salt), justamente porque não podem ser revertidas. A opção 'É de mão única (não reversível)' descreve corretamente essa característica essencial.

✗ Por que as outras estão erradas:

- *Pode ser revertido com a chave:* Essa é uma característica da criptografia simétrica ou assimétrica, não de funções hash. Na criptografia, a reversão é possível com a chave apropriada (simétrica) ou com a chave privada (assimétrica). Funções hash não possuem chave e não são projetadas para reversão. Portanto, essa afirmação está incorreta para hash. O CompTIA Security+ enfatiza que hash é unidirecional e não usa chaves, ao contrário da cifra.
- *Sempre encurta o texto pela metade:* Funções hash produzem uma saída de tamanho fixo,

independentemente do tamanho da entrada. Por exemplo, SHA-256 sempre gera 256 bits (32 bytes). Não há uma regra de 'encurtar pela metade'; o tamanho do digest é constante e definido pelo algoritmo. Além disso, a função hash não é uma compressão simples; ela deve ser resistente a colisões e pré-imagem. Essa afirmação é tecnicamente falsa e não descreve uma propriedade de hash.

- *Precisa de par de chaves:* Funções hash não utilizam chaves. Elas são algoritmos públicos e determinísticos que mapeiam dados de entrada para um resumo. O uso de par de chaves é característico de criptografia assimétrica (como RSA ou ECC), não de hash. Embora hashes possam ser usados em conjunto com chaves em HMAC, a função hash em si não requer chaves. Portanto, essa opção está incorreta.

3) A — Hash com salt (ex: bcrypt).

✓ **Por que está certa:** O armazenamento seguro de senhas de usuários exige o uso de funções de hash criptográfico lentas e resistentes a ataques de força bruta, como bcrypt, scrypt ou Argon2, combinadas com um salt único e aleatório por usuário. O salt impede ataques de tabela pré-computada (rainbow tables) e garante que senhas iguais produzam hashes diferentes. Funções como bcrypt são projetadas para serem computacionalmente custosas, ajustáveis por fator de custo, dificultando ataques de dicionário e força bruta offline. O hash é unidirecional, então mesmo que o banco de dados seja comprometido, o atacante não obtém a senha original diretamente, apenas o hash, que deve ser quebrado individualmente.

✗ Por que as outras estão erradas:

- *Criptografia AES reversível:* AES é uma cifra simétrica reversível: com a chave correta, o texto cifrado pode ser decifrado de volta ao texto claro. Se as senhas forem armazenadas cifradas com AES, qualquer pessoa que obtenha a chave de criptografia (por exemplo, através de comprometimento do servidor de aplicação ou do banco de dados) pode recuperar todas as senhas originais. Isso viola o princípio de que nem mesmo os administradores do sistema devem conhecer as senhas dos usuários. Além disso, a gestão da chave AES adiciona complexidade e risco desnecessários para um dado que nunca precisa ser recuperado em texto claro.
- *Texto claro protegido por firewall:* Armazenar senhas em texto claro significa que elas estão legíveis no banco de dados ou arquivo de configuração. Um firewall protege contra acessos não autorizados pela rede, mas não impede que um atacante que explore uma vulnerabilidade na aplicação, um insider malicioso ou um administrador com acesso ao banco de dados leia diretamente as senhas. A segurança em profundidade exige que o dado sensível seja protegido em repouso, independentemente de controles perimetrais. Firewall é um controle de rede, não de armazenamento de credenciais.
- *Base64:* Base64 é uma codificação reversível sem chave, frequentemente usada para representar dados binários em texto. Não oferece confidencialidade alguma: qualquer pessoa pode decodificar uma string Base64 instantaneamente. Armazenar senhas em Base64 é funcionalmente equivalente a armazená-las em texto claro, apenas com uma aparência ofuscada. Não há salt, não há custo computacional e não há resistência a ataques. É uma prática completamente inadequada para proteção de credenciais.

4) C — Hash SHA-256.

✓ **Por que está certa:** A alternativa correta é 'Hash SHA-256'. Funções de hash criptográfico, como SHA-256, são projetadas para serem unidirecionais (não reversíveis). Elas produzem um resumo de tamanho fixo (256 bits no caso do SHA-256) a partir de uma entrada de qualquer tamanho. Não existe uma chave secreta e não há forma prática de reverter o hash para obter a mensagem original, exceto por ataques de força bruta ou tabelas pré-computadas, que são inviáveis para entradas complexas. A CompTIA Security+ enfatiza que hashing garante integridade, não confidencialidade, e é irreversível por design.

✗ Por que as outras estão erradas:

- *Criptografia AES*: AES (Advanced Encryption Standard) é um algoritmo de criptografia simétrica reversível. Com a chave correta, o texto cifrado pode ser decifrado de volta ao texto claro. Portanto, é incorreto afirmar que AES não é reversível; sua reversibilidade é uma característica fundamental para a confidencialidade.
- *Criptografia RSA*: RSA é um algoritmo de criptografia assimétrica reversível. A chave privada permite decifrar o que foi cifrado com a chave pública (e vice-versa para assinaturas). Assim, RSA é reversível por natureza, desde que a chave apropriada seja conhecida. A alternativa é incorreta porque confunde criptografia com hashing.
- *Codificação Base64*: Base64 é uma codificação de dados que representa binário em texto ASCII usando 64 caracteres. Não é criptografia e é totalmente reversível (decodificação). Não oferece segurança alguma, apenas facilita transporte. A alternativa é incorreta porque Base64 não é uma função criptográfica e é trivialmente reversível.

5) A — Implementar a solução correspondente: SHA-256 padrão; MD5/SHA-1 quebrados (collision)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): SHA-256 padrão; MD5/SHA-1 quebrados (collision).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: Assinatura = hash cifrado com chave PRIVADA de quem assina....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): Assinatura = hash cifrado com chave PRIVADA de quem assina.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: Avalanche effect: 1 bit mudou = hash inteiro mudou....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701)

para a aula 1.4 (Hashing & Digital Signatures): Avalanche effect: 1 bit mudou = hash inteiro mudou.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: 'provides integrity but not confidentiality' = hash....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): 'provides integrity but not confidentiality' = hash.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: 'cannot deny that they signed' = digital signature (non-repudiation)....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): 'cannot deny that they signed' = digital signature (non-repudiation).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Cenário: 'arquivo é verificado com SHA-256 depois do download pra confiar q....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Hashing & Digital Signatures): Cenário: 'arquivo é verificado com SHA-256 depois

do download pra confiar que não foi alterado' = integridade por hash..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.